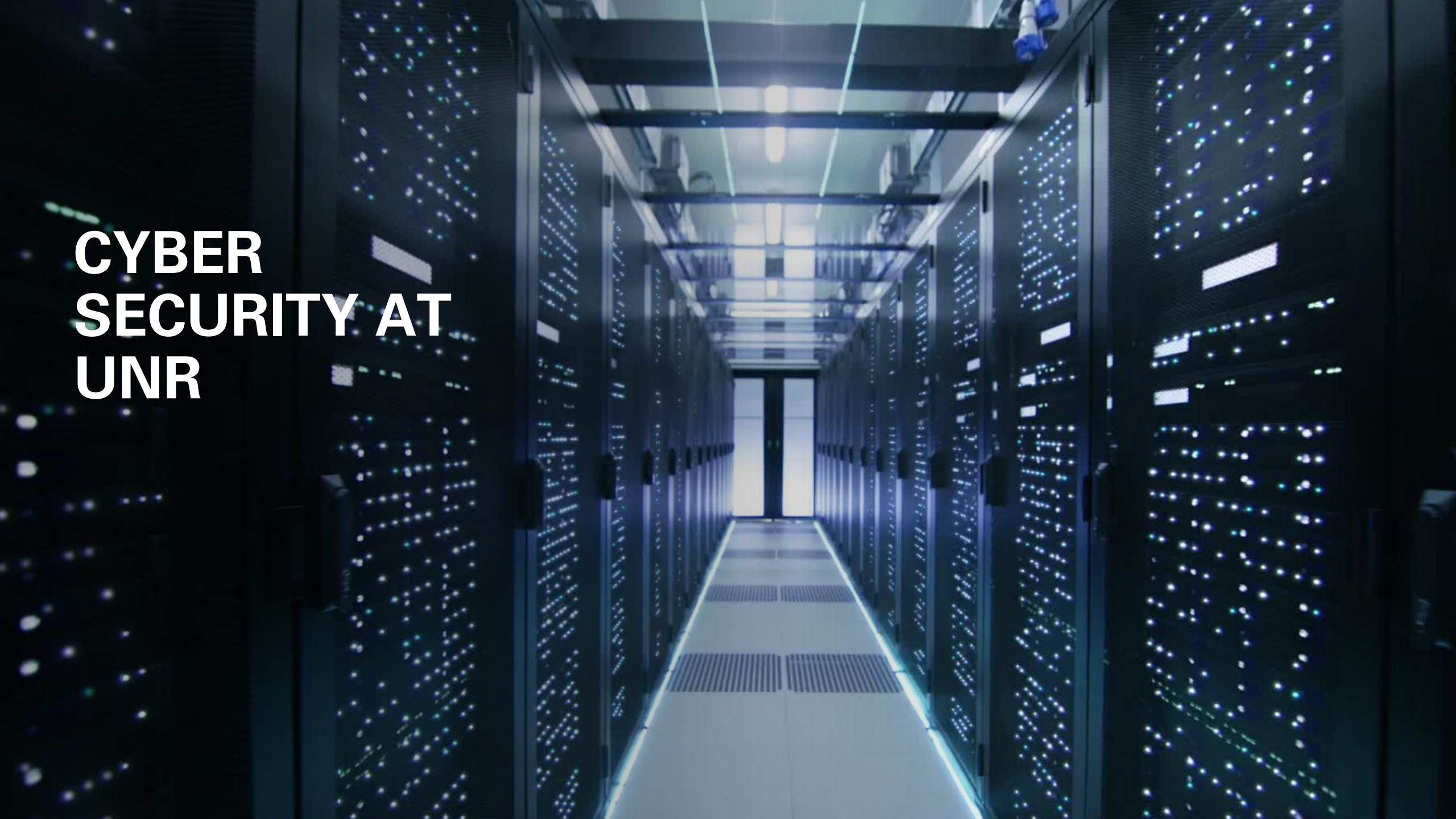


CYBER SECURITY AT UNR



What does a CISO and SOC Analyst do?



+

•

○

UNR's Cyber Security Landscape

- 28 Academic and Business Units
 - College of Science
 - College of Engineering
 - Business and Finance
 - Information Technology
 - Human Resources
- 6,000+ Faculty and Staff
 - Academic
 - Administrative
 - Classified
 - Student workers
- ~25,000 Students
 - Undergrad
 - Grad
 - Medical School
 - Dual Enrollment
- ~10,000 Endpoints
 - Windows
 - Mac
 - Linux
- ~1,250 Servers

UNR Information Security Staff

CISO

2 InfoSec Analysts

2 IT Compliance Analysts

1 Jr. InfoSec Analyst (student worker)

24/7/365 Managed SOC service

Top Cybersecurity Threats to UNR

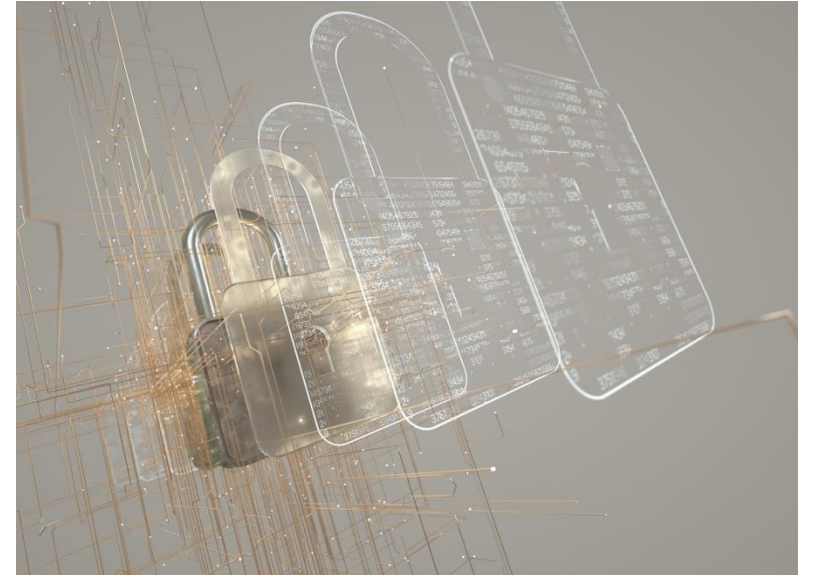
- Phishing and Social Engineering attacks
 - Bulk phishing
 - Spear Phishing / Business email compromise
 - Scareware
 - Vishing
- Ransomware attacks
- Malware
- APTs | Bad actors
- Insider threats
- Data breaches (first or third-party)



91% of all cyber attacks begin with a phishing email.

Top Cybersecurity Vulnerabilities for UNR

- Large attack surface
 - 30,000+ user accounts (on-premise and in the cloud)
- Credential theft
- Zero-day exploits
- Unpatched or inconsistent patching of software
- Human error
- Budget constraints



Internet Crime Complaints and Loss (FBI)



2024 Crime Types and Loss

BY COMPLAINT LOSS

Crime Type	Loss	Crime Type	Loss
Investment	\$6,570,639,864	Extortion	\$143,185,736
Business Email Compromise	\$2,770,151,146	Lottery/Sweepstakes/Inheritance	\$102,212,250
Tech Support	\$1,464,755,976	Advanced Fee	\$102,074,512
Personal Data Breach	\$1,453,296,303	Phishing/Spoofing	\$70,013,036
Non-Payment/Non-Delivery	\$785,436,888	SIM Swap	\$25,983,946
Confidence/Romance	\$672,009,052	Overpayment	\$21,452,521
Government Impersonation	\$405,624,084	Ransomware *	\$12,473,156
Data Breach	\$364,855,818	Harassment/Stalking	\$10,611,223
Other	\$280,278,325	Botnet	\$8,860,202
Employment	\$264,223,271	IPR/Copyright and Counterfeit	\$8,715,512
Credit Card/Check Fraud	\$199,889,841	Threats of Violence	\$1,842,186
Identity Theft	\$174,354,745	Malware	\$1,365,945
Real Estate	\$173,586,820	Crimes Against Children	\$519,424
Descriptor**			
Cryptocurrency	\$9,322,335,911		

FBI Financial Fraud Kill Chain

- Business Email Compromise
- Tech Support Fraud
- Romance Scams
- Data Breaches

IC3 Recovery Asset Team works with financial institutions and FBI field offices to assist in the freezing of funds for victims of fraudulent domestic and international transactions.



File a complaint at ic3.gov if you have become a victim of one of the above fraud activities.

A high-resolution image of Earth from space, showing the Western Hemisphere. The Earth's surface is covered in a dense network of city lights, appearing as bright white and yellow dots against the dark blue of the oceans and the black of the landmasses. The curvature of the Earth is visible at the top and bottom edges of the frame. The background is a deep black space filled with numerous stars.

What does a CISO do?

Three Principles to Cybersecurity: The CIA Triad

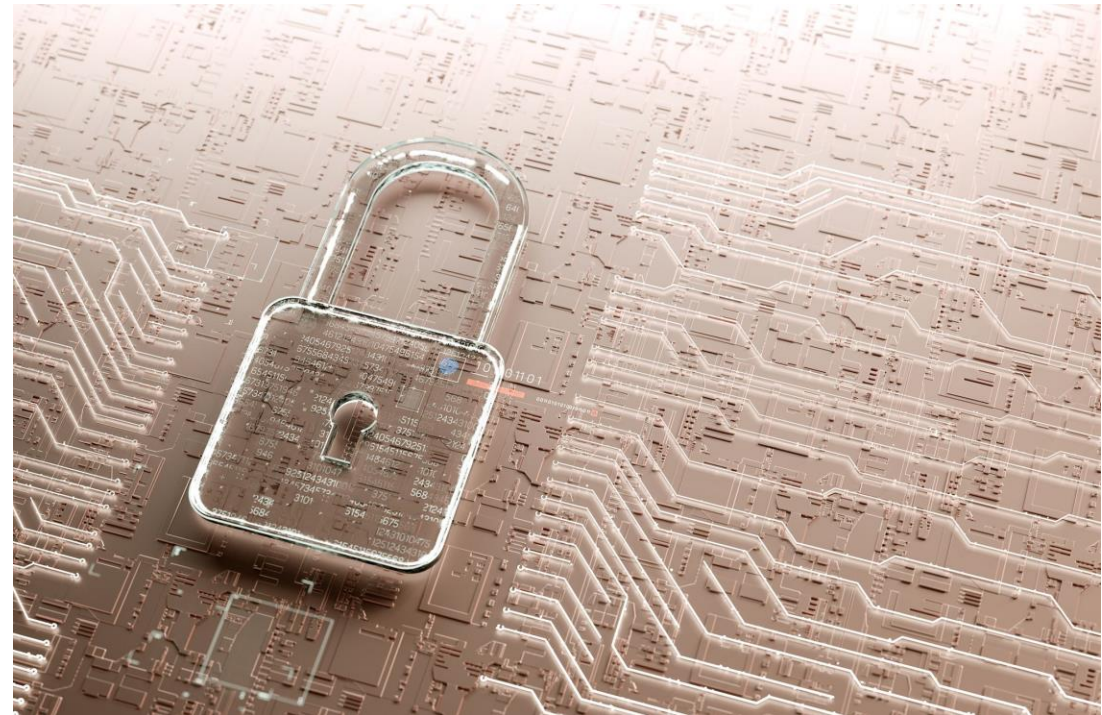
- **Confidentiality** ensures that data is only accessible by authorized personnel or systems
- **Integrity** ensures that data is accurate and unmodified in transit or storage
- **Availability** ensures that data is accessible when needed and not compromised by accidents or attacks

All security initiatives and controls are meant to reinforce at least one of these principles.



Cybersecurity and Managing Risk

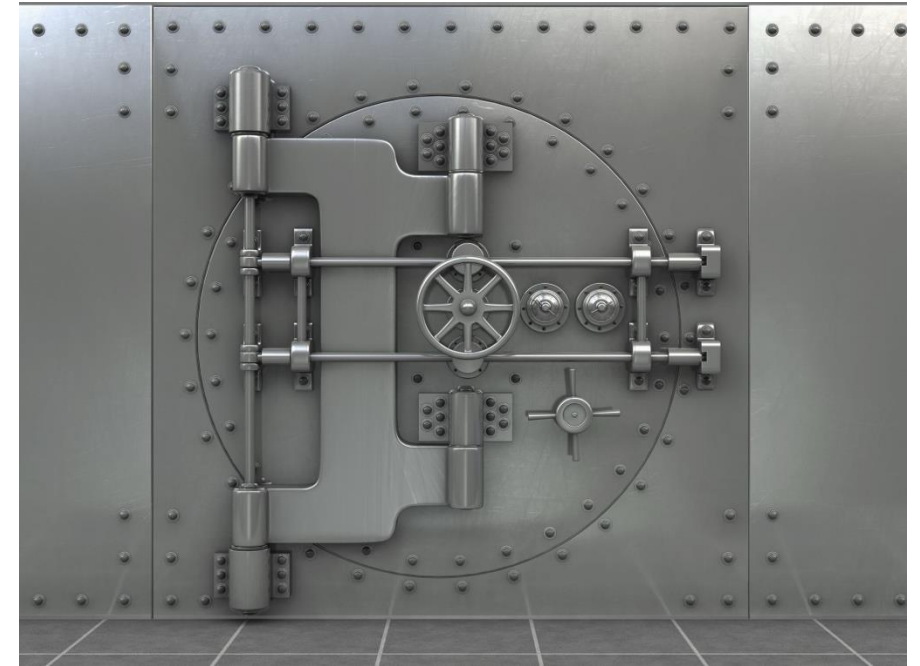
- At its core, cybersecurity is fundamentally about managing risk.
- The goal of risk management is to reduce risks to an acceptable level for the institution.
- Cybersecurity controls prevent unauthorized disclosure, alteration, and destruction of data
- The most simplistic risk definition:
 $\text{Risk} = \text{Threat} \times \text{Vulnerability}$
- It's much easier to control a vulnerability than it is to control a threat.



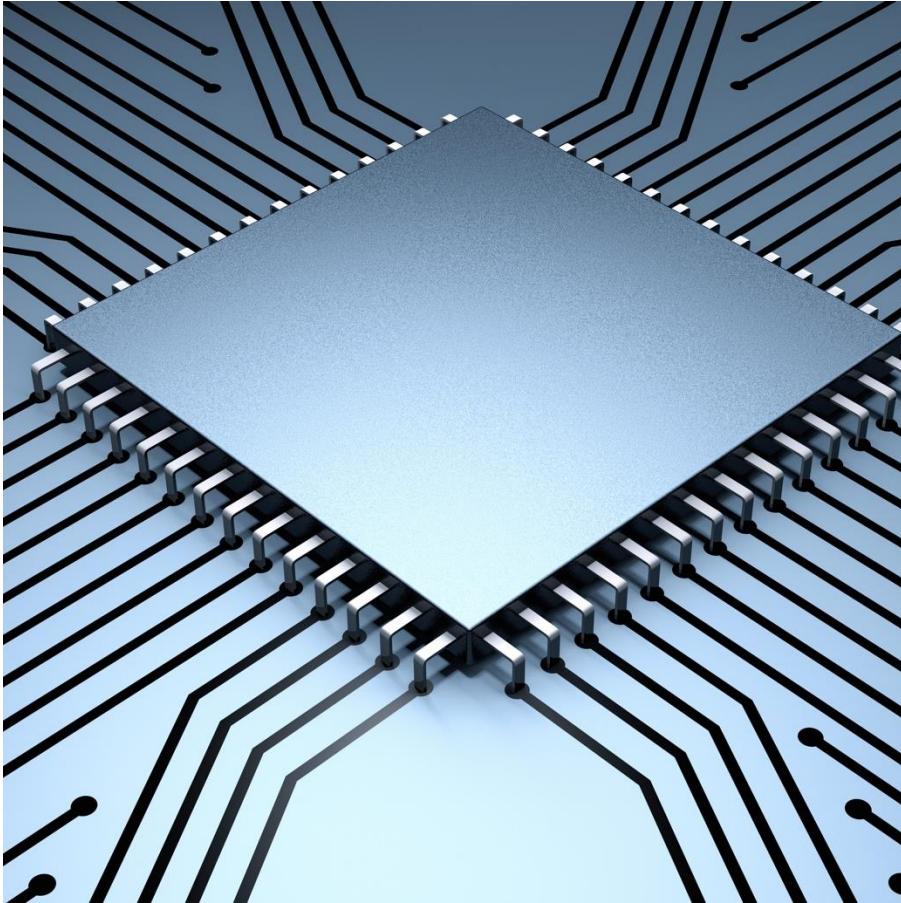


Implement Directive Controls

- Policies are strategic, high-level, and provide the 'what' and 'why' of an information security program
- Procedures provide detailed guidance for carrying out tasks
- Research institution's cybersecurity policies and procedures are guided by regulations such as HIPAA, PCI-DSS, GLBA, and FERPA.
- Examples of Cybersecurity Policies and Procedures
 - Acceptable Use Policy
 - Data Classification Policy
 - Data Retention Policy
 - System Configuration Policies
 - MFA reset request procedure
 - Password reset request procedure



Implement Technical Controls



- Strong passwords and two-factor authentication (MFA)
- Regular software updates and patches
- Firewalls and antivirus
- Email security
- Cybersecurity awareness training
- Continuous network scans of information systems
- Network segmentation
- Encryption (in-transit and at-rest)
- Audit logging (trust but verify)
- Principle of least privilege
- Physical
- Incident response management

Maintaining Regulatory Compliance



- Research institutions need to comply with various regulations and standards including HIPAA, PCI-DSS, GLBA, and FERPA.
- Compliance is **not optional**.
- Penalties for violations include monetary fines, loss of federal funding, and prison.

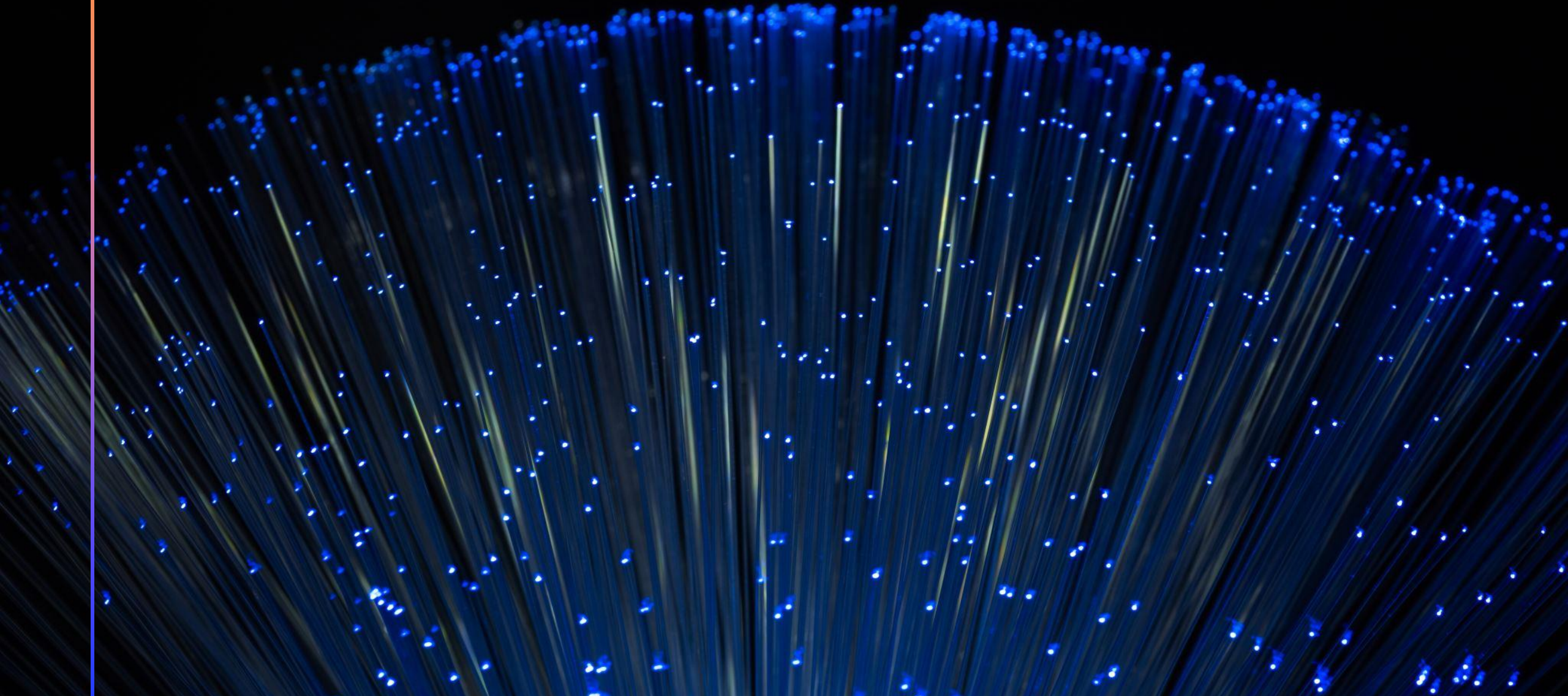
CISO Responsibilities

- Strategic Planning
 - Align security with business goals
 - Develop cybersecurity strategy and framework
- Risk Management
 - Conduct risk assessments
 - Evaluate and manage cyber risk
- Operations & Leadership
 - Lead cyber security operations
 - Manage security teams and budgets
- Technology & Defense
 - Implement secure processes and systems
 - Evaluate cyber security investments

CISO Tasks (Past Month)

- Complete and submit UNR's cyber insurance application
- Prepare and plan for annual penetration test
- Negotiate upcoming renewal with SOC vendor
- Conduct NIST 800-171 assessment for DoD
- Develop tabletop exercise for internal technology staff
- Meetings
- And more meetings

Working in a Security Operations Center (SOC)



What is a Security Operations Center (SOC)

A SOC is a centralized facility where cybersecurity teams monitor, detect, analyze, and respond to security incidents (hopefully 24/7/365)

Key Characteristics:

- Operates around the clock
- First line of defense against cyber threats
- Hundreds of security alerts daily
- Protects organization's systems and data

Primary Mission:

- Continuous monitoring of security tools and systems
- Rapid detection and response to security incidents
- Minimize damage from cyber attacks
- Maintain organizational security posture

Core SOC Analyst Responsibilities (General)

Detection & Monitoring

- Monitor SIEM dashboards
- Analyze security alerts and events
- Identify potential security threats
- Track suspicious network activity

Investigation & Analysis

- Investigate security incidents
- Collect and correlate log data
- Determine incident severity
- Perform forensic analysis
- Identify attack patterns

Core SOC Analyst Responsibilities

Continued

Response & Documentation

- Respond to confirmed incidents
- Contain and mitigate threats
- Implement remediation actions
- Create detailed incident reports

Continuous Improvement

- Tune security tools and reduce false positives
- Update detection rules
- Contribute to security policies
- Share threat intelligence

SOC at UNR

Daily Average

- 20 abuse emails per day
- 20 alerts per day

Typical Alerting Sources at UNR Include

- EDR (Endpoint Detection and Response)
- Microsoft ATP (Advanced Threat Protection)
- Firewall Alerts
- Network Traffic Sensors

Peak (Bad Days)

- 300 + abuse emails
- 100 + alerts



If you receive a suspicious email report it to us at abuse@unr.edu

Security Analyst Responsibilities at UNR

- Incident Response
 - Identify
 - Contain
 - Respond/Remediate
- SIEM Management
- Vulnerability Management
- Application Administration
- System Administration
- DLP management (Digital Loss Prevention)



Getting Started in Cybersecurity



Education

Bachelor's in Cybersecurity,
Computer Science, Information
Systems

Certifications

CompTIA Security +, Network
+

Participate in Events

Capture the Flag competitions,
cyber ranges

Work Experience (IT)

Help Desk, Desktop Technician,
Network Technician

Home Lab

Desktop OS, Server OS, Active
Directory, Networking, Coding,
Malware Analysis

2 TIPS IF INTERESTED IN A CYBER SECURITY CAREER

- A desire to explore every possible connection to an alert
- Have knowledge about other areas in IT other than security



Sources

- NIST.gov
- Whitehouse.gov
- CISA.gov
- IC3.gov
- Deloitte.com
- Microsoft | Microsoft Copilot
- Shutterstock

